

Week 1 Quiz
(All questions carry 1 point each)

1. A malicious email attack targeting a specific user or group of users, appearing to originate from a trusted source is:
- Spear Phishing
 - Man in the Middle Attack
 - Smurf Attack
 - Social media phishing

Ans: a. Spear Phishing

Explanation: Spear phishing attacks target specific users. It is similar to phishing, but attackers customize their approach for specific individuals or organizations.

2. A malicious attack where hackers encrypt an organization's data and demand payment to restore access is known as:
- Spyware
 - Ransomware
 - Whaling
 - Watering hole attack

Ans: b. Ransomware

Explanation: Ransomware denies access to a computer system or data until a ransom is paid.

3. Which of the following characteristics are most likely to be found in a phishing email?

- Sense of urgency and immediate action requests.
- Unusual or inappropriate requests
- Incorrect sender name or email address.
- All of the above.

Ans: d. All of the above

Explanation: The above mentioned are some of the characteristics which make phishing emails more recognizable.

4. From a managerial perspective, Information Security is generally understood as a:

- Product
- Technology
- Process
- Product, Technology and Process

Ans: c. Process

Explanation: Information security, often referred to as InfoSec, refers to the processes and tools designed and deployed to protect sensitive business information from modification, disruption, destruction, and inspection.

5. The practice of keeping an organization's network infrastructure secure from unauthorized access is known as:

- Data Security
- Network Security
- Information Security
- Operations Security

Ans: b. Network Security

Explanation: Network security is the field of cybersecurity focused on protecting computer networks from cyber threats.

6. Which of the following statements most accurately reflects the complex role of technology in cybersecurity?

- Technology acts as both a source of threats and a tool for defense.
- Technology is solely a source of threats and vulnerabilities.
- Technology plays a triple role: source of threats, asset to protect, and defense weapon.
- Technology solely serves as a defense weapon against cyberattacks.

Ans: c. Technology plays a triple role: source of threats, asset to protect, and defense weapon

Explanation: In the realm of cybersecurity, it is essential to have a clear understanding of the specific meaning of the term "technology" when it is being utilized.

7. _____ is a manipulation technique that exploits human weakness to gain private information, access, or valuables

- Spyware
- Logic Bomb
- Social Engineering
- Man in the Middle Attack

Ans: c. Social Engineering

Explanation: Social engineering technique gathers information by exploiting the weakest part of security, people.

8. True or False: The word "Cyber" in "Cybernetics" originates from the French language.

- True
- False

Ans: False

Explanation: Its of Greek origin derived from "κυβερνήτης" meaning steerman or pilot

9. The impact of a cyber security incident on organizations can include:

- Financial Loss
- Reputation Damage
- Regulatory fine
- All the above

Ans: d. All the above

Explanation: A cyber incident can have short-term as well as long-term impacts on a business, such as financial loss, reputation damage, loss of competitive advantage, reduction in credit rating, and increase in cyber insurance premiums.

10. True or False: A Vendor guarantees that their IoT solutions are 100% safe from cyberattacks. This statement can be

- True
- False

Ans: b. False

Explanation: Even robust systems are not truly 100% secure. Regardless of vendor claims, any connected device or software faces potential vulnerabilities that could be exploited by attackers with enough time, resources, and skill.

Week 2 Quiz
(All questions carry 1 point each)

1. CIA triad refers to:

- Confidentiality, Integrity and Availability
- Confidentiality, Integrity and Authentication
- Confidentiality, Integrity and Authorization
- Cybersecurity, Investigation and Authentication

Ans: a. Confidentiality, Integrity and Availability

Explanation: The industry standard for computer security since the development of the mainframe. The standard is based on three characteristics that describe the utility of information: confidentiality, integrity, and availability.

2. What aspect emerges from the intersection of 3 components of Information Security?

- Technology
- Policy
- Human Security
- None of the above

Ans: b. Policy

Explanation: The intersection of all 3 forms the central region from which "policy", primarily emerging from the management perspective, guides the security related decisions and practice.

3. -----, authentication and authorization are means to ensure CIA.

- Investigation
- Identification
- Classification
- Verification

Ans: b. Identification

Explanation: Identification refers to the process of proving one's identity to a system or service by providing credentials that claim the individual's identity.

4. Should all 27 cells of McCumber's Cube be addressed with the same priority?

- True
- False

Ans: b. False

Explanation: Although addressing each cell can provide a more comprehensive approach to security, The Security Model does not mandate that all 27 cells must be individually addressed. Organizations can prioritize their security efforts based on their specific requirements, resources and risks.

5. Which of the following is/ are the design principles of high availability systems?

- Eliminate single points of failure
- Ensure reliable crossover
- Identify failures in real time
- All the above

Ans: d. All the above

Explanation: The mentioned design principles help to maintain the availability of systems and services at all times.

6. In ensuring confidentiality, what is the crucial process that involves classifying information and individuals, and mapping them based on the level of access?

- Identification
- Authentication
- Authorization
- Encryption

Ans: c. Authorization

Explanation: In ensuring confidentiality, the crucial process involves classifying both information and individuals, and then mapping them based on the level of access they require.

7. In addition to cryptography, a number of measures may be used for confidentiality, including:
- a. Information classification
 - b. Secure document storage
 - c. Application of general security policies
 - d. All the above

Ans: d. All the above

Explanation: Measures such as information classification, secure document storage, application of general security policies, and education of information custodians and end users may be used for confidentiality

8. When a control provides assurance that every activity undertaken can be attributed to a named person or automated process, it is known as:
- a. Integrity
 - b. Accountability
 - c. Accessibility
 - d. Authenticity

Ans: b. Accountability

Explanation: Accountability in cybersecurity refers to the principle of holding individuals, organizations, or entities responsible for their actions. It involves assigning clear roles and responsibilities to ensure compliance.

9. Identify the components of Information Security
- a. Network Security
 - b. Computer & Data Security
 - c. Management of Information Security
 - d. All of the above

Ans: d. All the above

Explanation: Information Security entails all the 3 components such as Network Security, Computer & Data Security, Management of Information Security from whose intersection Policy emerges.

10. Which are the three types of power McCumber’s Cube identifies?
- e. Technologies
 - f. Policies and Practices
 - g. People
 - h. All the above

Ans: d. All the above

Explanation: “Technologies” encompass devices and products for protecting information systems and thwarting cybercriminals. “Policies and practices” entail procedures and guidelines to ensure cyber safety and adherence to best practices. “People” refers to the users who are aware and knowledgeable about their cyber environment and the associated threats.

Week 3 Quiz
(All questions carry 1 point each)

1. The process of defining and specifying the long-term direction to be taken by an organization, and the allocation and acquisition of resources needed to pursue this effort is known as:
- a. Governance
 - b. Security Management
 - c. Strategic Planning
 - d. Objectives

Ans: c. Strategic Planning

Explanation: Strategic planning sets the long-term direction to be taken by the organization and each of its component parts to guide organizational efforts and focus resources toward specific, clearly defined goals.

2. Which of the following statements best describes the relationship between GRC (Governance, Risk, and Compliance) and cybersecurity?
- a. GRC focuses solely on cybersecurity management and overlooks other risk management initiatives.
 - b. Cybersecurity is the primary focus of GRC, with minimal consideration for other risks.
 - c. GRC integrates cybersecurity as one component within the broader framework of enterprise risk management (ERM).
 - d. GRC is a standalone framework independent of cybersecurity and risk management.

Ans: c. GRC integrates cybersecurity as one component within the broader framework of enterprise risk management (ERM).

Explanation: GRC acknowledges cybersecurity as an essential aspect of risk management but places it within the broader context of enterprise risk management (ERM). This approach ensures that cybersecurity initiatives are aligned with overall organizational goals and risk management strategies, encompassing various risks beyond just cyber-related ones

3. A written document provided by management that inform employees and others in the workplace about proper behavior regarding the use of information and information assets are known as:

- a. Guidelines
- b. Information Security Policy
- c. De facto standard
- d. Practices

Ans: b. Information Security Policy

Explanation: An information security policy provides rules for the protection of the organization’s information assets.

4. Which approach to cybersecurity management treats cybersecurity as a separate category distinct from other risks an organization may face, and focuses solely on cybersecurity, depending on the size and nature of the organization?

- a. Standard Driven Approach
- b. Organization Planning Approach
- c. GRC Framework
- d. Risk Management Framework

Ans: a. Standard Driven Approach

Explanation: The Standard Driven Approach. It relies on open standards such as the NIST Cybersecurity Framework (American) and proprietary ISO/IEC 27001 standard for information security (European) to guide cybersecurity efforts.

5. Benefits of implementing a GRC in an organization include:
- a. Responsible operations
 - b. Data-driven decision-making
 - c. Improved cybersecurity
 - d. All the above

Ans: d. All the above

Explanation: By implementing GRC programs, the entire organization aligns its policies, decisions, and actions with organizational objectives.

6. What is the purpose of the COBIT maturity model?
- a. To assess an organization’s maturity in IT governance processes
 - b. To rank organizations based on their financial performance
 - c. To determine the efficiency of network infrastructure
 - d. To evaluate employee satisfaction levels in the IT department

Ans: a. To assess an organization’s maturity in IT governance processes

Explanation: COBIT provides a set of standards and practices for IT governance.

7. COSO’s ERM framework emphasizes:
- a. Operational efficiency
 - b. Risk identification and assessment
 - c. Regulatory compliance
 - d. Human resource management

Ans: b. Risk identification and assessment

Explanation: The COSO ERM Framework aims to help organizations understand and prioritize risks and create a strong link between risk, strategy and how a business performs.

8. Which characteristic distinguishes the approaches of COBIT, COSO, and COSO-ERM from specific standards like ISO or NIST?
- a. They prioritize cybersecurity over other risk management aspects.
 - b. They focus exclusively on small to medium-sized enterprises (SMEs).
 - c. They operate at the enterprise level rather than focusing on specific standards.
 - d. They are primarily developed by governmental regulatory bodies.

Ans: c. They operate at the enterprise level rather than focusing on specific standards.

Explanation: COBIT, COSO, and COSO-ERM operate at the enterprise level, encompassing various aspects of governance, risk, and compliance, unlike specific standards like ISO or NIST, which focus on cybersecurity at a more granular level.

9. Why might some countries be hesitant to adopt the ISO 27001 model?
- a. It is a mandatory standard with strict compliance requirements.
 - b. It is not recognized as a valid security framework by international organizations.
 - c. There are concerns about the model’s overall effectiveness compared to existing approaches.
 - d. It prioritizes specific security vendors or technologies.

Ans: c. There are concerns about the model’s overall effectiveness compared to existing approaches.

Explanation: Critics posit that there is no reason to believe the model is more useful than any other approach and it is not as complete as other frameworks.

10. Which of the following is not considered a principle or practice for securing IT systems?
- a. Implement layered security to ensure there is no single point of vulnerability.
 - b. Do not implement unnecessary security mechanisms.
 - c. Maximize the system elements to be trusted.
 - d. Assume that external systems are insecure.

Ans: c. Maximize the system elements to be trusted.

Explanation: Minimizing the system elements to be trusted is considered a principle for securing IT systems. (Source: NIST SP 800-14)

Week 4 Quiz
(All questions carry 1 point each)

1. A facility that provides only rudimentary services, with no computer hardware or peripherals is known as:

- a. Cold site
- b. Hot site
- c. Warm site
- d. Service bureau

Ans: a. Cold Site

Explanation: A cold site is a backup facility that has the necessary electrical and physical components of a computer facility, but does not have the computer equipment in place.

2. The amount of effort necessary to make the business function operational after the technology element is recovered is known as:

- a. Recovery Time Objective
- b. Work Recovery Time
- c. Maximum Tolerable Downtime
- d. Recovery Point Objective

Ans: b. Work Recovery Time

Explanation: The Work Recovery Time (WRT) is the remainder of the Maximum Tolerable Downtime (MTD) used to restore all business operations.

3. Contingency Planning includes:

- a. Incident response plan
- b. Disaster recovery plan
- c. Business continuity plan
- d. All the above

Ans: d. All the above

Explanation: Contingency Planning includes incident response planning (IRP), disaster recovery planning (DRP), and business continuity planning (BCP), in preparation for adverse events that become incidents or disasters.

4. An investigation and assessment of the various adverse events that can affect the organization, conducted as a preliminary phase of the contingency planning process, which includes a determination of how critical a system or set of information is to the organization's core processes and recovery priorities is known as:

- a. Risk assessment
- b. Business impact analysis
- c. Crisis management
- d. Incident damage assessment

Ans: b. Business impact analysis

Explanation: BIA helps determine which business functions and information systems are the most critical to the success of the organization.

5. The process that prepares an organization to reestablish or relocate critical business operations during a disaster that affects operations at the primary site is known as:

- a. Business continuity planning
- b. Disaster recovery planning
- c. Strategic Planning
- d. Operational planning

Ans: a. Business continuity planning

Explanation: The BC plan establishes critical business functions at an alternate site.

6. Which level of Organizational Planning typically addresses day-to-day activities and tasks?

- a. Strategic Planning
- b. Tactical Planning
- c. Operational Planning
- d. Top Management Planning

Ans: c. Operational Planning

Explanation: Operational Planning, the bottom level of Organizational Planning, typically addresses day-to-day activities and operational tasks within the organization.

7. The job function of the Chief Information Security Officer includes:

- a. Creating a strategic information security plan with a vision for the future of information security.
- b. Understanding fundamental business activities performed by the company and suggesting appropriate information security solutions that uniquely protect these activities.
- c. Improving the status of information security by developing action plans, schedules, budgets, status reports and top management communications
- d. All the above

Ans: d. All the above

Explanation: CISO is typically considered the top information security officer in an organization and has primary responsibility for the assessment, management, and implementation of information security in the organization.

8. What is the unit of analysis in the contingency planning approach?

- a. Business Assets
- b. Risk Assets
- c. Business Processes
- d. Risk Factors

Ans: c. Business Processes

Explanation: Unit of Analysis in Contingency Planning Approach is Business Processes whereas its Assets in Risk Management Approach

9. Which of the following is not a possible incident indicator?

- a. Presence of unfamiliar files
- b. Unusual consumption of computing resources
- c. Unusual system crashes
- d. Activities at unexpected times

Ans: d. Activities at unexpected times

Explanation: Activities at unexpected times are a probable indicator of an incident

10. What is the purpose of conducting an After Action Review (AAR) in incident response?

- a. To review and improve the effectiveness of the DRP
- b. To review and improve the effectiveness of the BCP
- c. To review and improve the effectiveness of the IRP
- d. To notify law enforcement agencies

Ans: c. To review and improve the effectiveness of the IRP

Explanation: AAR is conducted to assess the effectiveness of the Incident Response Plan (IRP) by examining actions taken during the incident, identifying areas for improvement, and refining response procedures for future incidents.

Week 5 Quiz
(All questions carry 1 point each)

1 . The primary function of a cybersecurity policy within an organization is to:

- a. Define a rigid set of penalties for security violations.
- b. Eliminate the need for ongoing security awareness training programs.
- c. Dictate specific technical security controls for implementation.
- d. Establish a comprehensive reference point for organizational cybersecurity practices.

Ans: d. Establish a comprehensive reference point for organizational cybersecurity practices.

Explanation: A well-crafted cybersecurity policy serves as a foundational document, outlining desired employee behaviors and security best practices. It's not focused solely on punishments, doesn't replace training, and allows flexibility in choosing specific controls.

2 . Which type of policy is related to an organization's strategic purpose, mission, and vision?

- a. Issue-specific information security policies (ISSP)
- b. Systems-specific information security policies (SysSP)
- c. Enterprise information security policy (EISP)
- d. Technical implementation policy

Ans: c.Enterprise information security policy (EISP)

Explanation: EISP policies are related to an organization's strategic purpose, mission, and vision, providing the overarching framework for its information security program.

3 . True or False: Standards are broad, abstract documents that provide detailed procedures for employees to comply with policies.

- a.True
- b.False

Ans: b.False

Explanation: Standards are more detailed statements of what must be done to comply with policy practices, while procedures and guidelines explain how employees will comply with policy.

4. Which of the following reflects the hierarchical top-down order of information security policies?

- a.Enterprise > Issue-Specific > Systems-Specific
- b.Systems-Specific > Issue-Specific > Enterprise
- c.Issue-Specific > Enterprise > Systems-Specific
- d.All three policy types are independent and unconnected.

Ans: a.Enterprise > Issue-Specific > Systems-Specific

Explanation: The hierarchy goes from broad organizational strategy (Enterprise) to specific technologies (Systems-Specific). Option (a) reflects this top-down order.

5. Which of the following components is typically included in the Enterprise Information Security Policy (EISP)?
- a. Incident response procedures
 - b. Statement of purpose
 - c. Software development guidelines
 - d. Employee performance evaluations

Ans: b.Statement of purpose

Explanation: The Statement of Purpose is one of the key components of the EISP, providing clarity on the purpose and objectives of the policy.

6. True or False: Systems-specific security policies (SysSPs) can be separated into two general groups, managerial guidance SysSPs and technical specifications SysSPs.

- a. True
- b. False

Ans: a. True

Explanation: SysSPs can be separated into managerial guidance SysSPs and technical specifications SysSPs, or they can be combined into a single policy document that contains elements of both.

7. _____ consists of details about user access and use permissions and privileges for an organizational asset or resource.

- a. Access Control Lists
- b. Configuration rules
- c. Authorized access and usage of equipment
- d. Authorization rules

Ans: a. Access Control Lists

Explanation: ACL include the specifications of authorization that govern the rights and privileges of users to a particular information asset.

8. True or False: Consequence-driven Cyber-informed Engineering (CCE) is a cyber defense concept that focuses on the lowest consequence events from an engineering perspective so that resource-constrained organizations receive the greatest return on their security investments.

- a. True
- b. False

Ans: b. False

Explanation: CCE focuses on the highest consequence events from an engineering perspective so that resource-constrained organizations receive the greatest return on their security investments.

9. _____ are nonmandatory recommendations the employee may use as a reference in complying with a policy.

- a. Practices
- b. Procedures
- c. Standards
- d. Guidelines

Ans: d. Guidelines

Explanation: Guidelines are recommendations for compliance.

10. Creating "air gaps" to isolate critical systems is a cyber hygiene practice that focuses on:

- a. Installing the latest security patches.
- b. Strengthening user authentication.
- c. Segmenting networks for improved security
- d. Keeping complex passwords up-to-date.

Ans: c. Segmenting networks for improved security

Explanation : An air gap is a security measure that isolates a critical system from other networks and even the internet. This physical or logical separation makes it much harder for attackers to reach the

Week 6 Quiz

(All questions carry 1 point each)

1. A determination of the extent to which an organization's information assets are exposed to risk is known as:

- a. Risk identification
- b. Risk control
- c. Risk assessment
- d. Risk Management

Ans: c. Risk assessment

Explanation: Risk assessment enables organizations to identify and address potential threats and vulnerabilities proactively.

2. _____ is the risk to information assets that remains even after current controls have been applied.

- a. Risk appetite
- b. Residual risk
- c. Inherent risk
- d. Contingency risk

Ans: b. Residual risk

Explanation: Residual risk is the risk that is left over after the risk management process has concluded.

3. Which of these is not a component of risk identification?

- a. Plan & organize the process
- b. Classify, value, & prioritize assets
- c. Specify asset vulnerabilities
- d. Determine loss frequency

Ans: d. Determine loss frequency

Explanation: Determine loss frequency (Likelihood) is a component of risk assessment.

4. The likelihood of an attack together with the attack frequency to determine the expected number of losses within a specified time range is known as:

- a. Loss frequency
- b. Attack success probability
- c. Loss magnitude
- d. Risk

Ans: a. Loss frequency

Explanation: Loss frequency is the probability that an organization will be the target of an attack, multiplied by the probability that the organization's information assets will be successfully compromised if attacked.

5. _____ is an information attack that involves searching through a target organization's trash for sensitive information.

- a. Shoulder surfing
- b. Network sniffing
- c. Dumpster diving
- d. Watering hole attacks

Ans: c. Dumpster diving

Explanation: Dumpster diving is a cyberattack where the attacker obtains sensitive information or documents that you've negligently discarded in the trash.

6. Risk management in cyber security involves three key steps. These steps are:

- a. Monitoring, auditing, and reporting.
- b. Identifying risks, assessing risk, and controlling risks.
- c. Training employees, patching vulnerabilities, and using firewalls.
- d. Investigating incidents, recovering data, and learning lessons.

Ans: b. Identifying risks, assessing risk, and controlling risks

Explanation: The core process of risk management involves identifying the organization's assets, & threats, assessing risks, and then taking steps to reduce the risks associated with those threats.

7. The "attack surface" in cyber security is a visualization tool that helps to understand:

- a. The effectiveness of different security tools.
- b. The relationship between various types of threats and the organization's assets.
- c. The complexity of the organization's network infrastructure.
- d. The cost of implementing different security controls.

Ans: b. The relationship between various types of threats and the organization's assets.

Explanation: The attack surface visualizes the potential threats on the Y-axis and the organization's assets on the X-axis. This helps identify points of vulnerability and prioritize risk reduction efforts.

8. During the Risk Identification phase, assets are classified into which of the following categories?

- a. Financial assets, Intellectual property, and Human resources
- b. Assets, Liabilities, and Equity
- c. Tangible assets, Intangible assets, and Fixed assets
- d. People, Procedures, Data and information, Software, Hardware, and Networking elements

Ans: d. People, Procedures, Data and information, Software, Hardware, and Networking elements

Explanation: Risk Identification begins with self-examination and Identification of info assets (6 categories) including people, procedures, data and information, software, hardware and networking elements.

9. Which formula accurately represents the calculation of risk in cyber security risk assessment?

- a. Risk = Loss frequency + Loss magnitude
- b. Risk = Loss frequency x Loss magnitude + Measurement Uncertainty
- c. Risk = (% Risk Mitigated by Controls) / (Loss Frequency x Loss Magnitude)
- d. Risk = Loss frequency - Loss magnitude + Measurement Uncertainty

Ans: b.Risk = Loss frequency x Loss magnitude + Measurement Uncertainty

Explanation: RISK is the Probability of a Successful Attack on the Organization (Loss Frequency = Likelihood • Attack Success Probability) Multiplied by the Expected Loss from a Successful Attack (Loss Magnitude = Asset Value • Probable Loss) Plus The Uncertainty of estimates of all stated values

10. You are a security analyst for a company that manages an online store with a customer database. Industry reports indicate a 10 percent chance of an attack this year, based on an estimate of one attack every 10 years. A successful attack could result in the theft of customer data. There is a 20% chance of the threat being able to materialize and achieve its objectives even in place of robust secure protection mechanisms. The customer database is most valued being an e-commerce company at 90 in a 1-100 scale. The IT department informed that 60% of the assets will be exposed after a successful attack. The estimation of measurements is 80% accurate. Calculate the risk associated to the asset with a potential SQL injection attack.

- a. 3.756
- b. 4.196
- c. 3.276
- d. 1.296

Ans: d. 1.296

Explanation:

RISK is the Probability of a Successful Attack on the Organization (Loss Frequency = Likelihood • Attack Success Probability) Multiplied by the Expected Loss from a Successful Attack (Loss Magnitude = Asset Value • Probable Loss) Plus The Uncertainty of estimates of all stated values

Likelihood :0.1, Attack Success Probability: 0.2

Loss Frequency: 0.1 * 0.2 = 0.02

Loss Magnitude: 0.6 * 90 = 54

Risk = 0.02 * 54 + 20% = 1.296

(0.1*0.2) * (90*0.6) + 20% => 0.02*54 +20% => 1.08 +0.216=1.296

Week 7 Quiz
(All questions carry 1 point each)

1. _____ is a comprehensive system comprising software, encryption techniques, protocols, legal arrangements, and third-party services that facilitate secure communication among users by utilizing digital certificates.

- a. Registration authority
- b. Public key infrastructure
- c. Digital signature
- d. Certificate authority

Ans: b. Public key infrastructure

Explanation: PKI, or public key infrastructure, encompasses everything used to establish and manage public key encryption.

2. Which ring does the kernel, the core of the operating system, typically operate?

- a. Ring 2
- b. Ring 1
- c. Ring 0
- d. Ring 3

Ans: c. Ring 0

Explanation: The kernel requires the highest level of privilege to manage hardware and system resources directly. Therefore, it usually operates in Ring 0, the innermost and most privileged ring.

3. Which of the following statements is not true?

- a. Hash functions are one-way.
- b. It is possible to attach a message authentication code (MAC) to allow only specific recipients to access the message digest.
- c. Hashing functions require the use of keys.
- d. Hash functions are used in password verification systems to confirm the identity of the user.

Ans: c. Hashing functions require the use of keys.

Explanation: Cryptographic hash functions do not require a key. Hashing functions take an input message and produce a fixed-length hash value.

4. Which of the following is not related to defense against rainbow cracking?

- a. Password hash salting
- b. key stretching
- c. Key strengthening
- d. Private key encryption

Ans: d. Private key encryption

Explanation: Rainbow is a technique used to crack password hashes by precomputing hash values and storing them in a table for quick lookup. Private key encryption is not related to this process.

5. Which of the following statements is/are correct?

- a. TCP is a connection-oriented protocol, while UDP is connectionless.
- b. TCP is comparatively faster than UDP.
- c. TCP provides reliable data delivery, while UDP does not.
- d. Both a and c.

Ans: d. Both a and c.

Explanation: TCP is reliable, ensures data delivery, and is suitable for applications where accuracy and sequencing are crucial. On the other hand, UDP is faster and suitable for real-time applications that prioritize speed over reliability.

6. Which of the following statements about Virtual Private Networks (VPN) are true?

- a. A VPN is an encrypted connection over the Internet from a device to a network.
- b. A VPN keeps the contents of the network messages hidden from observers who may have access to public traffic.
- c. A VPN protects its users by masking their IP address.
- d. All the above.

Ans: d. All the above.

Explanation: VPN is a mechanism for creating secure connections between computing devices and networks.

7. Endpoint Detection and Response (EDR) solutions are primarily focused on:

- a. Securing network perimeters and firewalls.
- b. Protecting individual user devices from threats.
- c. Monitoring and analyzing network traffic for malicious activity.
- d. Providing vulnerability assessments for servers and applications.

Ans: b. Protecting individual user devices from threats.

Explanation : EDR specializes in detecting and responding to threats on endpoints like laptops, desktops, mobile devices, IoTs etc.

8. Cryptojacking is a cyber attack that leverages a victim's computer resources for the attacker's financial gain. Which of the following best describes the attacker's activity in a cryptojacking attack?

- a. Encrypting the victim's data and demanding a ransom payment.
- b. Gaining unauthorized access to the victim's personal information for resale.
- c. Silently using the victim's processing power to solve complex mathematical problems for financial reward.
- d. Disrupting the normal operation of the victim's system to cause inconvenience.

Ans: c. Silently using the victim's processing power to solve complex mathematical problems for financial reward.

Explanation : Cryptojacking involves secretly using the victim's computer's processing power (CPU or GPU) to solve complex mathematical problems associated with cryptocurrency mining. These computations generate cryptocurrency for the attacker, providing them with financial gain without the victim's knowledge or consent.

9. What kind of infrastructure Advanced Persistent Threat (APT) groups are typically known for targeting?
- a. Personal computers of home users.
 - b. Critical infrastructure essential for national security (e.g., power grids, communication networks).
 - c. Public Wi-Fi networks at cafes or airports.
 - d. Outdated operating systems on personal devices of insignificant value

Ans: b. Critical infrastructure essential for national security (e.g., power grids, communication networks).

Explanation : APT groups typically target high-value targets with significant impact, not personal devices or public Wi-Fi.

10. Which of the following is NOT one of the stages in the Intrusion Kill Chain framework?

- a. Reconnaissance
- b. Exploitation
- c. Cleanup
- d. Command and Control

Ans: c. Cleanup

Explanation : The stages of the Intrusion Kill Chain typically include Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command and Control, and Actions on Objectives. "Cleanup" is not one of the recognized stages.

Week 8 Quiz
(All questions carry 1 point each)

1. The Cost-Benefit Analysis (CBA) formula for risk management decisions is given by:

- a. $CBA = ALE(prior) - ALE(post) - ACS$
- b. $CBA = ALE(prior) - ALE(post) + ACS$
- c. $CBA = ALE(prior) + ALE(post) - ACS$
- d. $CBA = ALE(prior) + ALE(post) + ACS$

Ans: a. $CBA = ALE(prior) - ALE(post) - ACS$

Explanation: ALE = Annualized Loss Expectancy, ACS = Annualized Cost of a Safeguard

2. In a cost-benefit analysis, _____ is the expected percentage of loss that would occur from a particular attack

- a. Single Loss Expectancy
- b. Exposure Factor
- c. Annualized Loss Expectancy
- d. None of the above

Ans: b. Exposure Factor

Explanation: Exposure Factor (EF) is the percentage of value lost by an asset because of an incident.

3. A _____ is a network security device that monitors traffic to or from a network and decides whether to allow or block specific traffic based on a defined set of security rules.

- a. Intrusion Detection and Prevention System
- b. Router
- c. Intrusion Detection System
- d. Firewall

Ans: d. Firewall

Explanation: Firewall monitors and filters network traffic based on an organization's security policies.

4. What risk management approach aims to minimize the impact of losses resulting from an actual incident, disaster, or attack by implementing thorough contingency plans and preparations?

- a. Mitigation risk control strategy
- b. Transference risk control strategy
- c. Defense risk control strategy
- d. Termination risk control strategy

Ans: a. Mitigation risk control strategy

Explanation: The mitigation risk control strategy aims to decrease the consequences of an attack, rather than focusing on diminishing the likelihood of the attack itself.

5. The product of the asset's value and the exposure factor is known as:

- a. Single Loss Expectancy
- b. Annualized Loss Expectancy (Prior)
- c. Annualized Rate of Occurrence
- d. Annualized Loss Expectancy (Post)

Ans: a. Single Loss Expectancy

Explanation: SLE is the calculated value associated with the most likely loss from an attack.

6. Which of the following is not true?

- a. Bit Stream ciphers encrypt data one bit at a time, while block ciphers encrypt data in fixed-size blocks.
- b. Bit Stream Cipher is used for Data in Transit Encryption, whereas Block Cipher is used for Data at Rest Encryption
- c. Bit Stream Cipher can operate as a Block Cipher but Block Cipher cannot operate as a Bit Stream Cipher
- b. Bit Stream ciphers are generally considered faster than block ciphers.

Ans: c. Bit Stream Cipher can operate as a Block Cipher but Block Cipher cannot operate as a Bit Stream Cipher

Explanation : Block Cipher can operate as a Bit Stream Cipher but Bit Stream Cipher cannot operate as a Block Cipher

7. The False Acceptance Rate (FAR) in biometrics refers to:

- a. The system mistakenly accepting an unauthorized user.
- b. The system correctly rejecting an unauthorized user.
- c. The time it takes for a system to identify a user.
- d. The user's frustration with the authentication process.

Ans: a. The system mistakenly accepting an unauthorized user.

Explanation : FAR measures the risk of unauthorized access due to the system mistakenly accepting someone who shouldn't be allowed.

8. The IAAA framework in the context of access control stands for?

- a. Isolation, Authentication, Authorization, Availability
- b. Identification, Authentication, Authorization, Accountability
- c. Inspection, Authentication, Access, Authorization
- d. Intrusion Detection, Analysis, Authorization, Administration

Ans: b. Identification, Authentication, Authorization, Accountability

Explanation : IAAA defines key steps in access control: Identifying users, verifying their credentials (authentication), granting appropriate access permissions (authorization), and holding them accountable for their actions.

9. What is a significant challenge associated with symmetric key encryption?

- a. Slower encryption and decryption compared to asymmetric methods.
- b. Limited compatibility with modern encryption algorithms.
- c. Higher computational cost for key generation.
- d. Key management: securely distributing and safeguarding the shared key.

Ans: d. Key management: securely distributing and safeguarding the shared key.

Explanation: In symmetric encryption, compromising the shared key compromises all communication. Securely distributing and managing this key can be difficult, especially as the number of communicating parties increases.

10. In risk management, which equation is used to calculate the expected loss per risk?

- a. Single Loss Expectancy (SLE) = Asset Value × Exposure Factor (EF)
- b. Annualized Loss Expectancy (ALE) = Single Loss Expectancy (SLE) × Annualized Rate of Occurrence (ARO)
- c. Asset Value = Single Loss Expectancy (SLE) × Exposure Factor (EF)
- d. Annualized Rate of Occurrence (ARO) = Asset Value × Single Loss Expectancy (SLE)

Ans: b. Annualized Loss Expectancy (ALE) = Single Loss Expectancy (SLE) × Annualized Rate of Occurrence (ARO)

Explanation: The equation for calculating the expected loss per risk in risk management is expressed as the Annualized Loss Expectancy (ALE) equals the Single Loss Expectancy (SLE) multiplied by the Annualized Rate of Occurrence (ARO).